

re_S25_A1_SL6_backend

Entrega no AVA

Nome: _____ Turma: _____

Título da atividade: Descomplicando o OAuth: autorização segura para APIs

1. Fluxos de OAuth

1.1 Conceito

OAuth é um protocolo de autorização que permite que aplicações acessem recursos protegidos sem expor credenciais do usuário.

1.2 Principais fluxos

1.2.1 Authorization Code Flow: indicado para aplicações web e *mobile* nas quais o usuário é redirecionado para autorizar o acesso e recebe um código que é trocado por um token de acesso.

1.2.2 Implicit Flow: usado para aplicações de cliente único (SPA) que não podem armazenar com segurança um segredo, embora tenha limitações de segurança.

1.2.3 Client Credentials Flow: aplicável a comunicações entre servidores, nas quais a aplicação se autentica diretamente com o servidor de autorização.

1.3 Exemplo prático

Um aplicativo de gerenciamento financeiro pode usar o *Authorization Code Flow* para permitir que os usuários autorizem o acesso a seus dados bancários sem compartilhar suas credenciais diretamente com o aplicativo.

2. Configuração de OAuth

2.1 Conceito

A configuração de OAuth envolve o registro da aplicação no provedor de autorização, a definição de redirecionamentos e o gerenciamento de tokens.

2.2 Boas práticas

2.2.1 Registrar a aplicação e definir escopos (*scopes*) de acesso de forma precisa;

2.2.2 Configurar URLs de redirecionamento seguras;

2.2.3 Gerenciar a expiração e renovação dos tokens para manter a segurança e a experiência do usuário.

2.3 Exemplo prático

Em um ambiente seguro, a equipe de desenvolvimento registra a aplicação em um provedor OAuth (como Google, Facebook ou um serviço customizado) e define os escopos necessários para acessar apenas os dados relevantes, garantindo que os tokens tenham um tempo de expiração adequado.

3. Exemplos práticos

3.1 Aplicação em um cenário real

Imaginem uma API que gerencia transações financeiras. Ao implementar OAuth, o fluxo *Authorization Code* permite que os usuários façam login através de um provedor confiável, recebendo um token que autoriza o acesso às suas transações sem que o aplicativo tenha acesso direto às credenciais.

3.2 Casos de uso

3.2.1 Integração com serviços de terceiros;

3.2.2 Delegação de acesso com controle granular dos escopos autorizados;

3.2.3 Garantia de que a comunicação entre o cliente e a API permaneça segura.

Roteiro da atividade

1. Estudo teórico

1.1 Leiam e revisem os conceitos de fluxos de OAuth, sua configuração e exemplos práticos de aplicação em cenários reais.

1.2 Caso prático

Imaginem que vocês são responsáveis por implementar OAuth para uma API de um sistema financeiro. Elaborem um plano que inclua:

1.2.1 A escolha do fluxo OAuth mais adequado (por exemplo, *Authorization Code Flow*);

1.2.2 A configuração necessária (registro da aplicação, definição de escopos e URLs de redirecionamento);

1.2.3 Um exemplo prático de como os tokens serão gerenciados (tempo de expiração, renovação etc.).

2. Execução

Redijam um documento detalhado que contenha o plano de implementação de OAuth de vocês, justificando cada escolha com base nas boas práticas e nos exemplos apresentados.

Perguntas da atividade

Imaginem que vocês receberam a seguinte mensagem no Slack:

"Time, recebemos uma solicitação urgente do setor de TI: precisamos revisar nosso processo de autorização para a API financeira, garantindo que o fluxo de OAuth esteja devidamente configurado. Como vocês recomendam que ajustemos nossa implementação com base no que discutimos?"

Situação fictícia produzida pela SEDUC-SP.

1. Como vocês explicariam a importância de escolher o fluxo OAuth adequado para nossa API e qual fluxo vocês recomendariam?
 2. Quais são os passos fundamentais para configurar corretamente o OAuth, desde o registro da aplicação até a definição dos escopos?
 3. De que maneira a gestão de tokens (expiração e renovação) contribui para a segurança da nossa API?
 4. Como vocês comunicariam essa estratégia para a equipe técnica, garantindo que todos estejam alinhados com as melhores práticas de OAuth?
-


